

Task 2

Brute force the website <http://testasp.vulnweb.com/> and find the directories that are present in the website.

Attack name :Directory Enumeration

Severity: Medium (CVSS Score: 5.3)

Reason:

Directory enumeration is a reconnaissance technique used to discover hidden files and directories on a web server. These directories may contain administrative panels, backup files, configuration files, or other resources that are not intended to be publicly accessible. Identifying such directories helps assess the security posture of the web application.

Steps to Reproduce:

Step 1: Perform Directory Enumeration Using Gobuster

Command: `gobuster dir -u http://testasp.vulnweb.com -w /usr/share/wordlists/dirb/common.txt`

Step 2: Gobuster Scan Result

```
(shravani@shravani)-[~]
$ gobuster dir -u http://testasp.vulnweb.com -w /usr/share/wordlists/dirb/c
ommon.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://testasp.vulnweb.com
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

_vti_cnf (Status: 301) [Size: 159] [→ http://testasp.vulnweb.co
m/_vti_cnf/]
aspnet_client (Status: 301) [Size: 164] [→ http://testasp.vulnweb.co
m/aspnet_client/]
avatars (Status: 301) [Size: 158] [→ http://testasp.vulnweb.co
m/avatars/]
cgi-bin (Status: 301) [Size: 158] [→ http://testasp.vulnweb.co
m/cgi-bin/]
cgi-bin/ (Status: 403) [Size: 1233]
html (Status: 301) [Size: 155] [→ http://testasp.vulnweb.co
m/html/]
HTML (Status: 301) [Size: 155] [→ http://testasp.vulnweb.co
m/HTML/]
images (Status: 301) [Size: 157] [→ http://testasp.vulnweb.co
m/images/]
Images (Status: 301) [Size: 157] [→ http://testasp.vulnweb.co
m/Images/]
jscripts (Status: 301) [Size: 159] [→ http://testasp.vulnweb.co
m/jscripts/]
robots.txt (Status: 200) [Size: 13]
t (Status: 301) [Size: 152] [→ http://testasp.vulnweb.co
m/t/]
T (Status: 301) [Size: 152] [→ http://testasp.vulnweb.co
m/T/]
templates (Status: 301) [Size: 160] [→ http://testasp.vulnweb.co
m/templates/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Fig 2: Gobuster Directory Enumeration Results

Analysis

The Gobuster scan successfully identified several directories on the target web server, including aspnet_client, avatars, images, scripts, templates, and cgi-bin. Most of the discovered directories returned HTTP 301 (Moved Permanently), indicating that they exist and redirect to a valid location, while cgi-bin returned HTTP 403 (Forbidden), showing that the directory exists but access is restricted. These findings provide a better understanding of the website's structure and help identify resources that may require further security assessment.

Directory	HTTP Status	Description
.vti_cnf/	301 (Moved Permanently)	FrontPage configuration directory
_vti_pvt/	301 (Moved Permanently)	Private FrontPage data directory
aspnet_client/	301 (Moved Permanently)	ASP.NET client-side resources
avatars/	301 (Moved Permanently)	Stores user avatar images
images/	301 (Moved Permanently)	Contains website image files
scripts/	301 (Moved Permanently)	Stores JavaScript and script files
templates/	301 (Moved Permanently)	Website template files
cgi-bin/	403 (Forbidden)	CGI scripts directory (access restricted)
_vti_inf/	301 (Moved Permanently)	FrontPage metadata directory

Impact

Advantages

1. Helps identify hidden directories and resources that are not visible through normal website navigation.
2. Provides a better understanding of the web application's directory structure for security assessment.
3. Assists in discovering administrative panels, static resources, and application files that may require further testing.

Disadvantages

1. Exposed directories can reveal information about the web application's structure, making reconnaissance easier for attackers.
2. If sensitive directories are publicly accessible, they may expose configuration files, backup files, or administrative interfaces.

Mitigation Steps

1. Restrict access to sensitive directories using proper authentication and authorization mechanisms.
2. Disable directory listing on the web server to prevent users from viewing directory contents.
3. Remove unused, test, or backup directories from the production environment.
4. Configure appropriate file and directory permissions to prevent unauthorized access.
5. Return generic error messages instead of revealing whether sensitive directories exist.

Resources Used: Kali Linux, Gobuster, DIRB Wordlist (common.txt), Target website: <http://testasp.vulnweb.com/>